

PROJECT AEGIS

AWS Cloud Security Master Study Guide

Labs 1-4

Account Security | IAM | Amazon S3 | Amazon VPC

Designed for

AWS certification study • cloud security interviews • Project Aegis review • technical recall

Study philosophy: understand why a control exists, recall it without notes, apply it to certification scenarios, then explain how you used it in Project Aegis.

Use this guide for AWS certification study, cloud security internship interviews, technical interviews, reviewing Project Aegis, understanding why each AWS control exists, and explaining the project to recruiters.

BIG PICTURE - PROJECT AEGIS

Project Aegis is a hands-on AWS cloud security portfolio. Instead of only reading about AWS services, the environment is built and validated one security layer at a time.

Lab 1 - AWS Account Hardening & Security Baseline: Secure the AWS account itself.

Lab 2 - Enterprise IAM & Least Privilege: Control identities and what they are allowed to do.

Lab 3 - Amazon S3 Security: Secure cloud data and test authorization.

Lab 4 - Amazon VPC & Network Architecture: Build and secure the network where future workloads will operate.

The progression is: AWS Account -> Account Security -> IAM / Identity -> Storage Security -> Network Security -> Future Compute / Monitoring / Detection.

The key idea is defense in depth. Cloud security is not one setting. We protect identity, data, network, compute, logging, detection, and response as separate but connected layers.

LAB 1 - AWS ACCOUNT HARDENING & SECURITY BASELINE

WHAT WAS THE PURPOSE?

Before deploying infrastructure, secure the AWS account itself. Everything else exists underneath the AWS account, so the foundation matters.

AWS ROOT USER

The root user is the identity associated with the AWS account itself. It has extremely powerful account-level privileges and should not be used as the normal everyday administrator.

Think of root as the master key to a building. You do not carry the master key around every day if you only need access to your office.

Root security principle: use root only when necessary. For normal administration, use appropriately authorized IAM identities.

Bad design: Root User -> Everything -> Used every day.

Better design: Root User -> Protected and rarely used; IAM Administrator -> Normal AWS administration.

MFA - MULTI-FACTOR AUTHENTICATION

MFA requires more than one authentication factor. Conceptually: Password + second authentication factor = MFA.

Why MFA matters: if someone steals only the password, that alone should not be sufficient when MFA is required. The more powerful an identity is, the more important strong authentication becomes.

ADMINISTRATIVE ACCESS

Instead of performing routine administration with root, establish a separate administrative identity/workflow. This separates the highest-privilege credentials from everyday administrative activity.

IAM GROUPS

An IAM group allows permissions to be managed for multiple IAM users. Conceptually: Permissions -> IAM Group -> IAM Users. Example: Administrative Permissions -> Administrators Group -> dylan-admin.

AWS BUDGETS

AWS Budgets helps monitor AWS spending. Cost monitoring can be security-relevant because unexpected spending may indicate a configuration mistake, forgotten resources, unexpected consumption, or potentially unauthorized resource creation or abuse.

LAB 1 - MUST KNOW

- Protect highly privileged identities.
- Enable MFA.
- Avoid routine use of root.
- Use appropriately authorized identities for daily administration.
- Monitor cloud spending.
- Secure the foundation before deploying workloads.

LAB 1 - INTERVIEW QUESTIONS

Q: Why shouldn't the AWS root user be used for normal administration?

A: The root user has extremely broad account-level privileges. Routine administration should use appropriately authorized identities so the highest-privilege credentials are exposed as little as possible.

Q: Why enable MFA?

A: MFA requires an additional authentication factor beyond the password, reducing the likelihood that a stolen password alone results in account compromise.

Q: Why configure AWS Budgets in a security project?

A: Cost monitoring can help identify unexpected resource consumption and provides operational visibility into the AWS environment.

LAB 2 - IAM & LEAST PRIVILEGE

WHAT IS IAM?

IAM stands for Identity and Access Management. IAM helps answer: WHO can perform WHAT ACTION on WHICH RESOURCE?

Example: WHO = developer1; WHAT = s3:GetObject; WHICH RESOURCE = specific S3 resources.

IAM USER

An IAM user represents an identity in AWS. Project Aegis used dedicated users such as dylan-admin, developer1, auditor1, and security1 to validate different job functions.

IAM GROUP

An IAM group is a collection of IAM users. Project Aegis organized users into Administrators, Developers, Security, and Auditors groups.

RBAC - ROLE-BASED ACCESS CONTROL

RBAC means access corresponds to job responsibilities.

Administrator: broad administrative capabilities.

Developer: permissions necessary for development tasks, not unrestricted account administration.

Security: visibility into security services and investigation information, not automatically full administration.

Auditor: visibility for review/compliance, generally without changing production resources.

PRINCIPLE OF LEAST PRIVILEGE

Grant an identity only the permissions necessary to perform its required function.

Bad approach: Developer needs S3 -> give AdministratorAccess.

Better approach: Developer needs specific S3 operations -> grant required S3 permissions -> do not grant unrelated administrative permissions.

Least privilege reduces potential damage from human error, credential compromise, malicious activity, and application compromise.

IAM POLICIES

IAM policies are JSON documents that define permissions.

Important components:

- Effect: Allow or Deny.
- Action: the AWS API operation being controlled, e.g. s3:GetObject or s3:PutObject.
- Resource: the AWS resource(s) the statement applies to.

ARN - AMAZON RESOURCE NAME

ARNs are standardized AWS identifiers for resources. Conceptually: arn:aws:service:region:account:resource. Policies commonly use ARNs to identify resources.

AWS-MANAGED POLICIES

Created and maintained by AWS. Project Aegis used ReadOnlyAccess for the Auditors group in the learning environment.

CUSTOMER-MANAGED POLICIES

Created and managed by the customer. Project Aegis examples included Developer-S3-Basic-Access and Security-Operations-ReadOnly. Custom policies can be tailored more precisely than broad managed policies.

VALIDATING IAM

We did not stop after creating policies. We tested them with dedicated identities and confirmed expected actions succeeded while restricted actions failed.

Why validation matters: a policy can contain the wrong resource, miss a required action, grant too much access, interact with another policy, or behave unexpectedly. A saved configuration is not proof that the security control works as intended.

EXPLICIT DENY

Memorize: EXPLICIT DENY OVERRIDES ALLOW.

If one applicable policy allows an action but another applicable policy explicitly denies it, the request is denied.

LAB 2 - MUST KNOW

- IAM = Identity and Access Management.
- User = identity.
- Group = collection of users.
- Policy = permissions document.
- RBAC = access organized around job function.
- Least privilege = only necessary permissions.
- AWS-managed policy = maintained by AWS.
- Customer-managed policy = maintained by the customer.
- Explicit Deny overrides Allow.
- Test security controls instead of assuming they work.

LAB 2 - INTERVIEW QUESTIONS

Q: What is IAM?

A: AWS Identity and Access Management controls authentication and authorization for AWS resources by defining identities and permissions.

Q: What is least privilege?

A: Granting only the permissions required for an identity or workload to perform its intended function.

Q: Why use IAM groups?

A: Groups simplify permission management by organizing permissions around shared job responsibilities instead of configuring every user independently.

Q: AWS-managed vs customer-managed policies?

A: AWS-managed policies are created and maintained by AWS. Customer-managed policies are created and controlled by the customer and can be tailored to specific requirements.

Q: Why validate IAM policies?

A: Creating a policy does not prove it behaves as intended. Testing confirms required actions are allowed and unauthorized actions are denied.

LAB 3 - AMAZON S3 SECURITY

WHAT IS AMAZON S3?

S3 stands for Simple Storage Service. Amazon S3 provides object storage. It is not the same as a traditional filesystem.

BUCKET

An S3 bucket is a container for objects. Project Aegis used project-aegis-lab3-df-4821.

OBJECT

An object is the actual data stored inside S3, such as Dylan_Fayad_Resume_v1.3.pdf.

OBJECT KEY

Every S3 object has a key, which is essentially the object's identifier/name within the bucket. Example: documents/resume.pdf.

S3 'FOLDERS'

S3 is object storage. A key such as photos/vacation/beach.jpg can be displayed by the console as if folders exist, but the apparent folder hierarchy is based on key prefixes.

BLOCK PUBLIC ACCESS

We enabled Block Public Access to reduce the risk of accidentally making S3 resources publicly accessible. Our Project Aegis bucket was intended to remain private.

OBJECT OWNERSHIP / ACLs

We selected Bucket Owner Enforced and disabled ACLs. We relied primarily on modern policy-based controls: IAM policies and bucket policies.

SERVER-SIDE ENCRYPTION

We enabled SSE-S3: Server-Side Encryption with Amazon S3 managed keys. This protects S3 object data at rest.

DATA AT REST VS DATA IN TRANSIT

Data at rest = stored data, such as S3 objects or database records.

Data in transit = data moving across a network.

SSE-S3 addresses encryption at rest for S3 objects.

S3 VERSIONING

Versioning preserves multiple versions of an object. If resume.pdf is uploaded again using the same key, version history can retain prior versions. Versioning improves recoverability from accidental overwrites, deletions, and certain destructive changes.

STORAGE CLASSES

We used S3 Standard, appropriate for frequently accessed data requiring low-latency access. Storage class selection is a tradeoff between access patterns, availability/retrieval requirements, and cost.

S3 URI VS OBJECT URL VS ARN

S3 URI: s3://bucket-name/object.pdf. Commonly used with AWS tools.

Object URL: HTTPS location associated with an object. Having a URL does not automatically mean the object is publicly accessible; permissions still apply.

ARN: standardized AWS resource identifier used by policies and services.

IAM POLICY VS BUCKET POLICY

IAM policy = identity-based. Think: what can this identity do?

Bucket policy = resource-based and attached to the S3 bucket. Think: who can access this resource, and how?

PROJECT AEGIS AUTHORIZATION EXPERIMENT

Test 1: applicable Allow permissions -> developer1 upload succeeded.

Test 2: added explicit Deny for s3:PutObject -> upload failed.

Test 3: removed explicit Deny -> upload worked again.

What did we prove? Allow -> success. Allow + explicit Deny -> denied. Remove explicit Deny -> success. Explicit Deny overrides Allow.

LAB 3 - MUST KNOW

- S3 = object storage.
- Bucket = container.
- Object = stored data.
- Key = object identifier/name inside a bucket.
- Block Public Access reduces accidental public exposure.
- Bucket Owner Enforced disables ACL-based ownership complexity for our design.
- SSE-S3 encrypts data at rest with S3-managed keys.
- Versioning preserves object versions.
- IAM policy = identity-based.

- Bucket policy = resource-based.
- Explicit Deny overrides Allow.

LAB 3 - INTERVIEW QUESTIONS

Q: What is S3?

A: Amazon S3 is AWS's object storage service. Data is stored as objects inside buckets.

Q: Bucket vs object?

A: A bucket is the container; an object is the stored data.

Q: Why use Block Public Access?

A: It helps prevent accidental public exposure when public access is not required.

Q: Why enable versioning?

A: It preserves multiple versions of objects, improving recoverability from accidental overwrites or deletion.

Q: What is SSE-S3?

A: Server-Side Encryption with Amazon S3 managed keys. S3 handles encryption and key management for stored objects.

Q: IAM policy vs bucket policy?

A: An IAM policy is identity-based; an S3 bucket policy is resource-based.

Q: What happens if Allow and explicit Deny both apply?

A: The request is denied because explicit Deny takes precedence.

LAB 4 - AMAZON VPC & NETWORK ARCHITECTURE

WHAT IS A VPC?

VPC stands for Virtual Private Cloud. A VPC is a logically isolated virtual network inside AWS where networked resources such as EC2 instances can operate.

EASY ANALOGY

AWS = city.

VPC = your property.

Subnet = section of property.

Route table = directions/network GPS.

Internet Gateway = road/path to the Internet.

Security Group = front door.

Network ACL = neighborhood gate.

PROJECT AEGIS VPC

We created project-aegis-vpc with IPv4 CIDR 10.0.0.0/16, spanning 2 Availability Zones with 2 public subnets and 2 private subnets.

CIDR

CIDR stands for Classless Inter-Domain Routing. CIDR notation describes IP address ranges. The /16 in 10.0.0.0/16 is the network prefix length. CIDR determines the address range available to a network or subnet.

AVAILABILITY ZONES

AWS Regions contain multiple Availability Zones. Using multiple AZs can improve availability and resilience by reducing dependence on a single failure domain.

PUBLIC SUBNET

A public subnet has routing that can provide Internet Gateway connectivity. A subnet is not public merely because of its name; routing is what matters.

PRIVATE SUBNET

A private subnet does not have a direct route to an Internet Gateway. Typical private resources include databases, internal application components, and backend services.

WHY DATABASES GO PRIVATE

Databases generally do not need arbitrary users on the Internet connecting directly to them. A better design is Internet User -> Public-Facing Application -> Private Database. This reduces direct exposure.

INTERNET GATEWAY

An Internet Gateway provides a VPC with a path for Internet connectivity. Attaching one does not automatically make every resource public; routing, addressing, and security controls still matter.

ROUTE TABLE

A route table determines where network traffic should be sent. Think of it as network GPS. A conceptual route is Destination 0.0.0.0/0 -> Internet Gateway.

0.0.0.0/0

In IPv4 CIDR notation, 0.0.0.0/0 represents all IPv4 addresses. In a security rule, Source 0.0.0.0/0 means connections can originate from any IPv4 address, subject to the rest of the configuration.

NAT GATEWAY

A NAT Gateway is commonly used to allow resources in private subnets to initiate outbound Internet connections without providing direct inbound Internet connectivity to those private resources through the NAT path. We did not create one because it was not required for this learning lab and NAT Gateways incur cost.

SECURITY GROUPS

A Security Group is a virtual firewall used with resources such as EC2 network interfaces. Think 'front door.' We created project-aegis-web-sg for future public web servers.

OUR SECURITY GROUP RULES

HTTP: TCP port 80 from 0.0.0.0/0 - public HTTP web traffic.

HTTPS: TCP port 443 from 0.0.0.0/0 - public HTTPS web traffic.

SSH: TCP port 22 from My IP - administrative access restricted to our trusted public IP.

WHY SSH WAS DIFFERENT

Public web users need access to ports 80 and 443. Arbitrary Internet users do not need administrative shell access. Restricting SSH to My IP reduces the attack surface compared with opening port 22 to 0.0.0.0/0.

SECURITY GROUPS ARE STATEFUL

Security Groups are stateful. Return traffic associated with an allowed connection is automatically tracked; you do not independently create a reverse rule just to permit the response for that established connection.

NETWORK ACL - NACL

A Network ACL operates at the subnet level. Think 'neighborhood gate.' NACLs are stateless, so inbound and outbound traffic must be considered independently.

SECURITY GROUP VS NACL

Security Group: resource/network-interface level; stateful; allow rules; front door.

Network ACL: subnet level; stateless; allow and deny rules; neighborhood gate.

PACKET FLOW CONCEPT

Traffic can be affected by both the Network ACL and the Security Group before reaching a resource. This is an example of defense in depth.

PROJECT AEGIS NETWORK ARCHITECTURE

Internet -> Internet Gateway -> Public Subnets in AZ A/B -> future public compute. Private Subnets in AZ A/B are reserved for future backend/database resources. This provides network segmentation, multi-AZ design, public/private separation, and a foundation for future compute and database architecture.

LAB 4 - MUST KNOW

- VPC = logically isolated AWS virtual network.
- CIDR = notation for IP address ranges.
- Public subnet = routing capable of reaching an Internet Gateway.
- Private subnet = no direct route to an Internet Gateway.
- Internet Gateway = VPC Internet connectivity component.
- Route table = determines traffic destinations.

- NAT Gateway = outbound Internet access path for private resources without direct inbound exposure through the NAT.
- Security Group = stateful resource/network-interface firewall.
- Network ACL = stateless subnet-level firewall.
- SSH = TCP 22.
- HTTP = TCP 80.
- HTTPS = TCP 443.
- 0.0.0.0/0 = all IPv4 addresses.

LAB 4 - INTERVIEW QUESTIONS

Q: What is a VPC?

A: A VPC is a logically isolated virtual network in AWS where I can define IP ranges, subnets, routing, and network security controls for AWS resources.

Q: Public vs private subnet?

A: A public subnet has routing that provides a path to an Internet Gateway. A private subnet does not have a direct route to an Internet Gateway.

Q: Why put a database in a private subnet?

A: Databases generally do not need direct Internet exposure. Private subnets reduce attack surface and allow application components to communicate with databases internally.

Q: What does a route table do?

A: It determines where network traffic is directed based on destination routes.

Q: What does an Internet Gateway do?

A: It provides a VPC with a path for Internet connectivity when appropriate routing and resource configuration are present.

Q: What does a NAT Gateway do?

A: It allows resources in private subnets to initiate outbound Internet connections while avoiding direct inbound Internet exposure through the NAT.

Q: Security Group vs Network ACL?

A: Security Groups are stateful controls associated with resources/network interfaces. Network ACLs are stateless subnet-level controls.

PORTS TO KNOW

SSH = 22 - secure remote shell administration.

HTTP = 80 - standard HTTP web traffic.

HTTPS = 443 - HTTP protected using TLS.

HOW LABS 1-4 CONNECT

Lab 1: Is the AWS account itself protected?

Lab 2: Who should be allowed to do what?

Lab 3: How should stored data be protected?

Lab 4: How should the network be segmented and exposed?

Architecture: AWS Account -> Lab 1 Account Security -> Lab 2 IAM -> authorization decisions -> Lab 3 Secure Storage + Lab 4 Secure Network.

ABSOLUTE MUST-KNOW LIST

IAM = Identity and Access Management.

Least Privilege = grant only necessary permissions.

RBAC = permissions organized according to job function.

Explicit Deny = overrides Allow.

S3 = object storage.

Bucket = container for objects.

Object = stored data.

Versioning = preserves versions of objects.

SSE-S3 = server-side encryption using S3-managed keys.

Block Public Access = helps prevent unintended public S3 access.

IAM Policy = identity-based permission policy.

Bucket Policy = S3 resource-based policy.

VPC = logically isolated AWS virtual network.

CIDR = notation describing IP address ranges.

Public Subnet = subnet with routing capable of Internet Gateway connectivity.

Private Subnet = no direct route to an Internet Gateway.

Internet Gateway = VPC Internet connectivity component.

Route Table = determines where traffic goes.

NAT Gateway = outbound Internet connectivity for private resources.

Security Group = stateful resource/network-interface firewall.

Network ACL = stateless subnet-level firewall.

SSH = TCP 22.

HTTP = TCP 80.

HTTPS = TCP 443.

0.0.0.0/0 = all IPv4 addresses.

CERTIFICATION PRACTICE

1. Which AWS service manages identities and permissions? A EC2, B IAM, C S3, D VPC. Answer: B.

2. Which principle says users should receive only required permissions? A High Availability, B Least Privilege, C Encryption, D Load Balancing. Answer: B.
3. An IAM policy allows an action, but another applicable policy explicitly denies it. What happens? A Allow wins, B Random result, C Deny wins, D AWS asks admin. Answer: C.
4. What type of storage is Amazon S3? A Object, B RAM, C CPU, D Network. Answer: A.
5. What helps recover previous versions of an S3 object? A Security Groups, B Versioning, C VPC, D IAM Groups. Answer: B.
6. Where should a database normally be placed? A Public subnet, B Private subnet. Answer: B.
7. Which is stateful? A NACL, B Security Group. Answer: B.
8. Which is stateless? A Security Group, B NACL. Answer: B.
9. What port is HTTPS? A 22, B 80, C 443, D 3389. Answer: C.
10. What does 0.0.0.0/0 represent? A One computer, B AWS administrators, C All IPv4 addresses, D One VPC. Answer: C.

PROJECT AEGIS INTERVIEW STORY

Project Aegis is my hands-on AWS cloud security portfolio. I started by establishing an AWS account security baseline using MFA, a dedicated administrative workflow, and cost monitoring. I then designed an IAM environment using RBAC and least-privilege policies for administrator, developer, security, and auditor functions. For storage security, I built an S3 environment using Block Public Access, versioning, SSE-S3 encryption, and bucket policies. I validated AWS authorization by intentionally introducing an explicit Deny and confirming that it overrode existing Allow permissions before restoring access. I then designed a multi-AZ VPC with separate public and private subnets, routing, an Internet Gateway, and a Security Group that allows web traffic while restricting SSH to a trusted IP. I document the architecture, policies, validation results, and lessons learned in GitHub.

WHY THIS STORY IS STRONG

It demonstrates: I designed + I configured + I secured + I tested + I intentionally broke + I diagnosed + I restored + I documented.

STUDY METHOD

Pass 1 - Understand: read explanations and ask why each service/control exists.

Pass 2 - Recall: hide answers and explain IAM, least privilege, S3, VPC, Security Groups, and NACLs in your own words.

Pass 3 - Certification: practice scenario questions, not only definitions.

Pass 4 - Interview: speak answers aloud and connect knowledge to what you built in Project Aegis.

CURRENT KNOWLEDGE CHECKLIST

- Why the AWS root account should be protected
- Why MFA matters
- What IAM does
- IAM users vs groups
- RBAC

- Least privilege
- IAM policy structure
- AWS-managed vs customer-managed policies
- Explicit Deny
- S3 buckets vs objects
- S3 object keys
- Block Public Access
- Bucket Owner Enforced
- S3 Versioning
- SSE-S3
- IAM policies vs bucket policies
- S3 authorization testing
- What a VPC is
- CIDR
- Availability Zones
- Public vs private subnets
- Internet Gateways
- NAT Gateways
- Route tables
- Security Groups
- Network ACLs
- Stateful vs stateless
- Ports 22, 80, and 443
- 0.0.0.0/0
- Network segmentation
- How Labs 1-4 connect together

NEXT - LAB 5

Amazon EC2 & Compute Security. The next architecture layer is: Internet -> Internet Gateway -> Public Subnet -> Security Group -> EC2 Instance.